

Exercício 6 — Papel do CWE

Descreva o papel do CWE nas práticas de desenvolvimento seguro de software.

Como os desenvolvedores podem aproveitar o CWE para melhorar a qualidade e a segurança do código?

6. Papel do CWE

Qual é o Papel do CWE no Desenvolvimento Seguro de Software?

O CWE atua como uma **linguagem compartilhada para fraquezas** entre desenvolvedores, equipes de segurança e ferramentas.

Em vez de cada equipe inventar sua própria definição de "código ruim", todos se referem ao mesmo catálogo. Isso torna possível treinar desenvolvedores, configurar ferramentas e escrever políticas em torno de um padrão comum.

*O CWE não diz o que foi quebrado — diz **quais padrões evitar** ao escrever código.*

Como Desenvolvedores Podem Usar o CWE

1. Aprenda primeiro as fraquezas mais perigosas

O **CWE Top 25** é uma lista classificada das fraquezas de software mais comuns e perigosas.

Exemplos: | CWE | Fraqueza | |---|---| | CWE-79 | Cross-Site Scripting (XSS) | | CWE-89 | Injeção de SQL | | CWE-22 | Travessia de Diretório | | CWE-787 | Escrita Fora dos Limites | | CWE-306 | Autenticação Ausente |

Desenvolvedores que conhecem esses padrões os evitam instintivamente durante a codificação.

2. Use o CWE durante a revisão de código

Ao revisar pull requests, as equipes podem referenciar IDs CWE para sinalizar problemas específicos:

```
Esta entrada não é sanitizada antes de ser inserida na consulta.  
→ CWE-89: Risco de Injeção de SQL. Use consultas parametrizadas.
```

Isso torna o feedback preciso e educativo — não apenas "isso está errado".

3. Configure ferramentas SAST com CWE

Ferramentas de análise estática (Semgrep, SonarQube, Checkmarx) mapeiam suas descobertas para IDs CWE.

Os desenvolvedores podem: - Configurar regras para **bloquear builds** se um CWE-89 ou CWE-79 for detectado. - Acompanhar quais categorias CWE aparecem com mais frequência em seu código. - Priorizar correções com base na severidade do CWE.

4. Aplique o CWE na modelagem de ameaças

Durante o design — antes de escrever uma única linha de código — as equipes podem perguntar:

"Quais fraquezas CWE poderiam afetar este recurso?"

Isso desloca a segurança para a esquerda: encontrar o problema no momento do design custa quase nada. Encontrá-lo em produção custa tudo.

5. Use o CWE para treinar a equipe

As categorias CWE se mapeiam diretamente para conteúdo de treinamento. Um desenvolvedor que continua introduzindo descobertas CWE-89 pode receber treinamento direcionado em Injeção de SQL — não um curso genérico de segurança.

O Ciclo de Desenvolvimento com CWE

Design	→ Pergunte: quais CWEs podem afetar isso?
Codificação	→ Aplique padrões seguros para evitar CWEs conhecidos
Revisão	→ Sinalize violações CWE com referências precisas
CI/CD	→ Bloqueie merge se CWEs críticos forem detectados pelo SAST
Produção	→ CVEs que aparecem podem ser rastreados até sua causa raiz CWE

Resumo

O CWE transforma a segurança de uma preocupação vaga em uma lista de verificação concreta. Desenvolvedores que entendem CWE escrevem menos CVEs — porque eliminam a causa raiz antes que a vulnerabilidade exista.